Incident Report: HawkEye Stealer Infection

Oct 26, 2026 · @Karabo Isaac Komota

Summary

A workstation (`BEIJING-5CD1-PC` , 10.4.10.132) in the `pizzajukebox.com` domain downloaded and ran a HawkEye Keylogger – Reborn v9 payload on 10 April 2019, then emailed the user's saved browser and Outlook credentials to an attacker-controlled mailbox. Severity: **High**. Credentials for the user `roman.mcguire` , including a bank site, a personal AOL account and the corporate mail account, must be treated as compromised.

The scenario given with the lab: an accountant opened an invoice email with a download link, and suspicious traffic followed. The capture shows the download, the malware's check-ins and the data theft. It does not show the original phishing email.

Timeline

The capture starts at about 20:37 UTC on 10 April 2019 and runs 64 minutes. Times below are seconds after the first packet.

Time	Event
+26 s	Host looks up the domain controller (`PizzaJukebox-DC`) over DNS and LDAP. Normal domain activity.
+47 s	DNS lookup of `proforma-invoices.com` .
+48 s	HTTP GET `/proforma/tkraw_Protected99.exe` from 217.182.138.150. About 2 MB Windows executable downloaded over unencrypted HTTP.
+68 s	Malware checks its public IP at `bot.whatismyipaddress.com` (66.171.248.178). Repeats about every 10 minutes (7 times in total).
+68 s	DNS lookup of `macwinlogistics.in` , the domain of the exfiltration mailbox.

Time	Event
+69 s	SMTP session to 23.229.162.69 on port 587. The malware logs in and sends an email containing stolen passwords.
+673 s to end	The same SMTP exfiltration repeats every 10 minutes (7 sessions in total, last at +3696 s). The server closes the first with a lost-connection error.
+2664 s	Fresh DNS, LDAP, SMB and Kerberos traffic to the domain controller. Not analysed in depth yet.

Indicators of compromise

Type	Value	Note
Domain	`proforma-invoices.com`	Hosts the malware
URL	`http://proforma-invoices.com/proforma/tkraw_Protected99.exe`	Payload download
IP	217.182.138.150	Payload server
File	`tkraw_Protected99.exe`	PE32 executable, 2,025,472 bytes
MD5	`71826ba081e303866ce2a2534491a2f7`	Payload
SHA-1	`b482d64a43f6bfbf758166ecba680b7f0c59a4f7`	Payload
SHA-256	`62099532750dad1054b127689680c38590033fa0bdfa4fb40c7b4dcb2607fb11`	Payload
Domain	`macwinlogistics.in`	Exfiltration mail domain
IP	23.229.162.69 (port 587)	SMTP server used for exfiltration
Email	`sales.del@macwinlogistics.in`	Account used to send and receive the stolen data
Domain	`bot.whatismyipaddress.com`	IP check (not malicious itself)

Type	Value	Note
Victim host	`BEIJING-5CD1-PC`, 10.4.10.132, public IP 173.66.146.112	Infected workstation

Exfiltration analysis

The malware sent stolen data by email, authenticated with a login for `sales.del@macwinlogistics.in` on SMTP port 587. The login was visible in the capture because it used base64 encoding without encryption (the server offered STARTTLS but it was not used). The message is from and to the same address.

- **Subject:** "HawkEye Keylogger - Reborn v9 - Passwords Logs - roman.mcguire \ BEIJING-5CD1-PC - 173.66.146.112". This identifies the malware family and version.
- **Content:** a password dump from the victim's browsers and mail client.
- **Stolen items:** an AOL account login (Internet Explorer), a Bank of America login (Chrome), and the corporate Outlook profile for `roman.mcguire@pizzajukebox.com` (POP3 `pop.pizzajukebox.com`, SMTP `smtp.pizzajukebox.com`).
- **Passwords:** present in clear text in the capture; deliberately left out of this report.

The attacker's mailbox account is itself an indicator: it is probably a compromised or purpose-made account on a logistics company's mail system, so that company should be notified.

MITRE ATT&CK mapping

Tactic	Technique	Evidence
Initial Access	T1566 Phishing (suspected)	Scenario: invoice email with a download link
Execution	T1204 User Execution	User downloaded and ran the invoice executable
Command and Control	T1105 Ingress Tool Transfer	Payload fetched over HTTP
Discovery	T1016 System Network Configuration Discovery	Public IP lookup at `bot.whatismyipaddress.com`

Tactic	Technique	Evidence
Credential Access	T1555.003 Credentials from Web Browsers	Saved browser passwords dumped
Credential Access	T1056.001 Keylogging	HawkEye Keylogger
Exfiltration	T1048.003 Exfiltration Over Unencrypted Non-C2 Protocol	Stolen data emailed over SMTP

Detection ideas and recommendations

Immediate response

1. Isolate `BEIJING-5CD1-PC` from the network and re-image it.
2. Reset the passwords for `roman.mcguire` on the domain, Outlook/POP3 and every site in the stolen dump, and tell the user to change the bank and AOL passwords.
3. Block `proforma-invoices.com`, `macwinlogistics.in`, 217.182.138.150 and 23.229.162.69 at the proxy and firewall.
4. Search mail logs for the invoice email and remove it from other mailboxes.
5. Check the domain controller logs for use of the stolen account after the infection.

Detection rules

- Alert when a workstation connects to an external SMTP server on ports 25, 465 or 587. Only the mail servers should do this.
- Alert on a Windows executable (`MZ` header, `application/x-msdownload`) downloaded over plain HTTP.
- Alert on repeated requests to IP-lookup sites at a fixed interval from one host.
- Match the subject pattern "HawkEye Keylogger" in outbound mail, and the payload hashes above.

Hardening

- Filter or sandbox email links and attachments, and train staff on invoice phishing, especially in finance.
- Block outbound SMTP from workstations by default.
- Stop browsers from saving passwords and use multi-factor authentication on mail and banking accounts.